PolicyGraphAudit-RT

Compliance Audit Report
Heterogeneous GNN Privacy Analysis

Buku Kimia SMA Kelas 11

`com.muhdi.bukukimiasmakelas11`

Developer	Muhdi Studio
Genre	BOOKS_AND_REFERENCE
Installs	1,000+
Audit Date	2026-04-26

Overall Risk Score	0.30	MEDIUM

0	0	5	0
Consistent	Mismatches	Over-disclosure	Undeclared

Research prototype · Ongoing research | Policy: https://sites.google.com/view/muhdi/buku-kimia-sma-kelas-11

Executive Summary

Buku Kimia SMA Kelas 11 declares 0 data type(s) collected and 0 shared in its Play Data Safety label, across 5 data type(s) analyzed. Our heterogeneous GNN audit model identifies **0 potential undeclared collection(s)** — data types implied by embedded SDK signals but absent from both label and policy — and **0 policy-vs-label mismatch(es)**. Overall risk score: **0.30 (MEDIUM)**.

Top discrepancies by risk:

- **app_interactions**: Over Disclosure (confidence 1.00)
- **date_of_birth**: Over Disclosure (confidence 1.00)
- **device_id**: Over Disclosure (confidence 1.00)

Class definitions:

CONSISTENT: Label, policy, and SDK signals agree.

POLICY_LABEL_MISMATCH: Label discloses data not mentioned in policy.

OVER_DISCLOSURE: Policy mentions data not declared in label.

UNDECLARED_COLLECTION: SDK signals collection undisclosed in label and policy.

Discrepancy Table

Sorted by risk class (undeclared collection first). Y/N: label=data-safety label, policy=policy text, sdk=SDK signal.

Data Type	Class	Conf.	Evidence
app_interactions	**Over Disclosure**	1.00	label:N policy:Y sdk:N
date_of_birth	**Over Disclosure**	1.00	label:N policy:Y sdk:N
device_id	**Over Disclosure**	1.00	label:N policy:Y sdk:N
files_and_docs	**Over Disclosure**	1.00	label:N policy:Y sdk:N
phone_number	**Over Disclosure**	1.00	label:N policy:Y sdk:N

Evidence Trails

Detailed evidence for UNDECLARED_COLLECTION or confidence > 0.85 non-CONSISTENT findings.

Discrepancy: app_interactions — Over Disclosure (confidence 1.00)

Label declares collection: **No**

Label declares sharing: **No**

Policy text mentions: **Yes**

SDK collection signals: **No** — none

Recommended action: Review whether 'app_interactions' is genuinely collected. If yes, add to label; if no, remove from policy.

Discrepancy: date_of_birth — Over Disclosure (confidence 1.00)

Label declares collection: **No**

Label declares sharing: **No**

Policy text mentions: **Yes**

SDK collection signals: **No** — none

Recommended action: Review whether 'date_of_birth' is genuinely collected. If yes, add to label; if no, remove from policy.

Discrepancy: device_id — Over Disclosure (confidence 1.00)

Label declares collection: **No**

Label declares sharing: **No**

Policy text mentions: **Yes**

SDK collection signals: **No** — none

Recommended action: Review whether 'device_id' is genuinely collected. If yes, add to label; if no, remove from policy.

Discrepancy: files_and_docs — Over Disclosure (confidence 1.00)

Label declares collection: **No**

Label declares sharing: **No**

Policy text mentions: **Yes**

SDK collection signals: **No** — none

Recommended action: Review whether 'files_and_docs' is genuinely collected. If yes, add to label; if no, remove from policy.

Discrepancy: phone_number — Over Disclosure (confidence 1.00)

Label declares collection: **No**

Label declares sharing: **No**

Policy text mentions: **Yes**

SDK collection signals: **No** — none

Recommended action: Review whether 'phone_number' is genuinely collected. If yes, add to label; if no, remove from policy.

Methodology

PolicyGraphAudit-RT represents each Android app as a tri-partite heterogeneous graph connecting three layers: **Privacy Policy** text (OPP-115 segment classification), **Play Data Safety Labels** (declared data types and purposes), and **Runtime Evidence** (inferred SDK trackers via Exodus Privacy). A 2-layer HeteroConv R-GCN encodes all three layers jointly; an MLP classifier head predicts discrepancy classes for each (App, DataType) pair.

The model was trained under an edge-masking protocol (30% of label-determining edges removed) to prevent circularity. It achieves **macro F1 = 0.956** on 39 held-out apps (UNDECLARED_COLLECTION F1 = 0.974), trained on 252 apps and 3,202 labeled pairs. Model card: https://github.com/PolicyGraphAudit-RT/reports/blob/main/reports/m5_model_card.md.

Known limitations: (1) Privacy labels are from a 2022 Play Store snapshot. (2) SDK presence is inferred via category-level priors, not measured from APK bytecode. (3) Policy classifier uses MiniLM + logistic regression (OPP-115 macro F1 = 0.70). (4) Labels are rule-derived weak supervision, not human-annotated. (5) English-language Android apps only.

Disclaimer